Note de sécurité

1. Hypothèses

Le serveur est **hébergé par l'État mais considéré comme curieux** : il doit fonctionner sans pouvoir lire. Le navigateur de l'agent est de confiance tant qu'il est enrôlé.

2. Menaces prises en compte et protections

Menace	Protection	Vérifié par
Lecture de la base, des médias ou du trafic par l'hébergeur	Chiffrement de bout en bout Matrix (Olm/Megolm, bibliothèque officielle, **aucune cryptographie maison**) ; pièces jointes et vocaux chiffrés dans le navigateur	scénario complet : aucun marqueur en clair dans la base ni les médias (journaux contrôlés aussi, mais peu bavards : contrôle faible)
Client modifié postant du texte lisible	Module serveur `no_plaintext` : refuse (403) les types de message, les états personnalisés, le motif d'une suppression et toute « enveloppe chiffrée » qui n'a pas la forme d'un message Megolm	refus testés ; aucun `m.room.message` stocké ; chemins non couverts : §4
Intrus non enrôlé	Inscription fermée, invités refusés, connexion par mot de passe désactivée dans Synapse (identité par Keycloak seul), salons sur invitation, API d'administration non exposée	inscription 403, jeton forgé 401, adhésion sans invitation 403
Mot de passe volé	**Second facteur TOTP obligatoire** ; octroi direct par mot de passe **refusé sur tous les clients**, y compris le client intégré `admin-cli` (corrigé après relecture indépendante)	le mot de passe seul ne délivre aucun code d'autorisation ni aucun jeton
Départ d'un agent, appareil perdu	Révocation : Keycloak puis Synapse coupés, jetons et appareils supprimés, sortie des salons, **nouvelle clé de groupe**	jeton refusé en moins de 2 s ; clé de groupe changée ; client ouvert déconnecté
Falsification d'un accusé ou d'une pièce jointe	Empreinte SHA-256 dans l'accusé ; empreinte des fichiers vérifiée ; **clé d'appareil de l'auteur authentifiée** par le chiffrement de groupe (l'identifiant d'appareil n'est que déclaré)	fausse empreinte ignorée ; fichier falsifié rejeté ; clé = clé réelle
Fuite par transfert, relecture, vol de session	Transfert interdit (recalculé selon le niveau) ; expiration ; CSP stricte ; texte inséré sans HTML ; médias authentifiés ; jeton d'administration vérifié (RS256 imposé)	tests unitaires et d'intégration

3. Ce que le serveur voit malgré tout (mesuré dans la base)

Visible	Détail	Réduction
Comptes et appareils	identifiants, nom affiché, appareils avec **adresse IP, navigateur et dernière activité, conservés tant que l'appareil existe**	ni e-mail ni téléphone ; historique des connexions purgé au-delà de 7 jours (réglage, non mesuré)
Salons	**nom, sujet, membres, droits** : états non chiffrés par Matrix	ne pas y mettre d'information sensible
Pour chaque message	expéditeur, salon, heure, taille ; tous apparaissent comme « chiffré »	texte, niveau et nature ne se lisent pas ; un fichier ou un vocal se reconnaît à son dépôt séparé, et la taille peut trahir le genre
Fichiers	taille et heure ; **pas de nom**, type générique	contenu chiffré
Présence, accusés publics, notifications externes	0 ligne mesurée	présence désactivée côté serveur ; notre client n'émet ni accusés publics ni notifications

« Qui parle à qui, et quand » reste **visible** de l'équipe d'exploitation. L'identité (ministère, fonction, rôle) vit dans Keycloak, séparée du serveur de messagerie.

4. Limites connues

- **Noms de salons et membres lisibles** par le serveur (limite figée par un test).
- **Chemins que le module ne ferme pas** : texte dans les champs libres d'états standards (nom, sujet, nom affiché), faux « texte chiffré » de bonne forme, fichier téléversé en clair, données de compte et profil. Le serveur ne peut pas le savoir.
- **Jetons d'accès stockés en clair dans la base** (comportement de Synapse) : qui lit la base peut usurper une session.
- **Captures d'écran** : impossibles à bloquer sur le web ; le flou et le filigrane dissuadent.

- **Expiration et horloges** : masquage par chaque client, suppression par l'expéditeur s'il est en ligne (sinon le message chiffré reste) ; heures propres à chaque appareil.
- **Vérification des appareils** absente de l'interface : un serveur malveillant pourrait ajouter un appareil à un compte.
- Jeton et clés dans le navigateur, **non chiffrés au repos**.
- **Révocation** : n'efface pas ce que l'agent a déjà lu ; un compte révoqué ne se réactive pas (nouvel identifiant à enrôler).
- **Rôles** : seul `admin` est appliqué (API d'administration). L'autorité d'émettre une instruction de service repose sur le rôle de **modérateur du salon**, pas sur `chef_de_service`.
- Démonstration en HTTP local : `skip_verification` (Synapse), `sslRequired: none` (Keycloak), identifiants publics : **à retirer en production** (`DEMO_ACCOUNTS=false`).
- Secrets éprouvés sous Docker Desktop (Windows) seulement ; pas d'audit externe ni de test de charge.

5. Vérifications automatisées

`bash scripts/test-security.sh` : tests d'intégration contre la pile en marche (serveur aveugle, révocation en groupe, intrus, second facteur, fonctions d'innovation). Des tests de mutation et une relecture indépendante ont révélé des défauts réels, corrigés et couverts : message en clair accepté par le serveur ; octroi direct sans second facteur par `admin-cli` ; fichier de configuration lisible de tous.

6. Avant une mise en service réelle

Miroir interne des images et paquets ; TLS partout ; retrait des réglages de démonstration ; secrets en coffre ; console Keycloak sur réseau d'exploitation ; rétention des anciens messages chiffrés ; sauvegardes chiffrées ; audit externe.